

Informe de Auditoría de Seguridad

Sistema Analizado: Localhost

Fecha de generación: 2025-11-29 14:27:09

Versión del motor: 1.0

Clasificación: CONFIDENCIAL

Auditoría automatizada · Red Team · Hardening · CIS Benchmark

Índice

1. Resumen de la Auditoría
2. Hallazgos
3. Remediaciones Detalladas
4. Playbooks de Seguridad
5. Conclusión Técnica

Resumen de la Auditoría

Este informe resume los hallazgos detectados durante el análisis automatizado de seguridad.

Severidad	Recuento
Crítica	1
Alta	8
Media	10
Baja	0
Info	0
Total	19

Las secciones posteriores detallan los hallazgos, su impacto técnico, indicadores asociados y recomendaciones completas de remediación.

Hallazgos

CHK-SSH-1 — Permisos inseguros en sshd_config

Referencia CIS: 5.1.1

Severidad: ALTA

Explicación breve:

Permisos incorrectos permiten modificar configuración crítica de SSH.

Evidencia:

```
Archivo dummy contiene BAD_PERMISSIONS
```

Recomendación:

```
chmod 600 /etc/ssh/sshd_config
```

CHK-SSH-4 — Falta AllowUsers o AllowGroups

Referencia CIS: 5.1.4

Severidad: MEDIA

Explicación breve:

Limitar usuarios reduce superficie de ataque.

Evidencia:

```
No se encontró ninguna línea AllowUsers ni AllowGroups
```

Recomendación:

```
Añadir AllowUsers <usuario>
```

CHK-SSH-5 — SSH Banner no configurado

Referencia CIS: 5.1.5

Severidad: MEDIA

Explicación breve:

Un banner legal advierte sobre uso no autorizado.

Evidencia:

```
No se encontró parámetro Banner
```

Recomendación:

```
Añadir Banner /etc/issue.net
```

CHK-SSH-6 — Ciphers inseguros detectados

Referencia CIS: 5.1.6

Severidad: ALTA

Explicación breve:

Los cifrados CBC son débiles frente a ataques conocidos.

Evidencia:

```
Se encontró el cipher inseguro: aes128-cbc
```

Recomendación:

```
Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

CHK-SSH-7 — ClientAliveInterval demasiado alto

Referencia CIS: 5.1.7

Severidad: MEDIA

Explicación breve:

Valores altos retrasan tiempo de detección de sesiones muertas.

Evidencia:

```
Línea 12: ClientAliveInterval 600
```

Recomendación:

```
ClientAliveInterval 300
```

CHK-SSH-7 — ClientAliveCountMax demasiado alto

Referencia CIS: 5.1.7

Severidad: MEDIA

Explicación breve:

Evita mantener sesiones inactivas por demasiado tiempo.

Evidencia:

```
Línea 13: ClientAliveCountMax 10
```

Recomendación:

```
ClientAliveCountMax 3
```

CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

Referencia CIS: 5.1.8

Severidad: ALTA

Explicación breve:

Evita tunelización no autorizada.

Evidencia:

```
Línea 14: AllowTcpForwarding yes
```

Recomendación:

```
AllowTcpForwarding no
```

CHK-SSH-9 — GSSAPIAuthentication debe estar en 'no'

Referencia CIS: 5.1.9

Severidad: MEDIA

Explicación breve:

Reduce superficie de ataque en autenticación.

Evidencia:

```
Línea 15: GSSAPIAuthentication yes
```

Recomendación:

```
GSSAPIAuthentication no
```

CHK-SSH-10 — HostbasedAuthentication debe estar en 'no'

Referencia CIS: 5.1.10

Severidad: ALTA

Explicación breve:

Evita autenticación basada en confianza entre hosts.

Evidencia:

```
Línea 2: HostbasedAuthentication yes
```

Recomendación:

```
HostbasedAuthentication no
```

CHK-SSH-11 — IgnoreRhosts debe estar en 'yes'

Referencia CIS: 5.1.11

Severidad: ALTA

Explicación breve:

Los archivos rhosts son altamente inseguros.

Evidencia:

```
Línea 3: IgnoreRhosts no
```

Recomendación:

```
IgnoreRhosts yes
```


CHK-SSH-13 — LoginGraceTime debe ser 60 o menos

Referencia CIS: 5.1.13

Severidad: ALTA

Explicación breve:

Reduce ventana para ataques de fuerza bruta.

Evidencia:

```
Línea 8: LoginGraceTime 120
```

Recomendación:

```
LoginGraceTime 60
```

CHK-SSH-14 — LogLevel incorrecto

Referencia CIS: 5.1.14

Severidad: MEDIA

Explicación breve:

Nivel adecuado permite registrar actividad sospechosa.

Evidencia:

```
Línea 20: LogLevel debug
```

Recomendación:

```
LogLevel INFO
```

CHK-SSH-16 — MaxAuthTries demasiado alto

Referencia CIS: 5.1.16

Severidad: ALTA

Explicación breve:

Evita ataques de fuerza bruta.

Evidencia:

```
Línea 7: MaxAuthTries 10
```

Recomendación:

```
MaxAuthTries 4
```

CHK-SSH-17 — MaxSessions demasiado alto

Referencia CIS: 5.1.17

Severidad: MEDIA

Explicación breve:

Evita abuso de sesiones múltiples.

Evidencia:

```
Línea 19: MaxSessions 50
```

Recomendación:

```
MaxSessions 10
```

CHK-SSH-19 — PermitEmptyPasswords debe ser 'no'

Referencia CIS: 5.1.19

Severidad: ALTA

Explicación breve:

Evita sesiones sin contraseña.

Evidencia:

```
Línea 6: PermitEmptyPasswords yes
```

Recomendación:

```
PermitEmptyPasswords no
```

CHK-SSH-20 — PermitRootLogin debe estar en 'no'

Referencia CIS: 5.1.20

Severidad: CRITICA

Explicación breve:

Evita accesos directos al usuario root.

Evidencia:

```
Línea 5: PermitRootLogin yes
```

Recomendación:

```
PermitRootLogin no
```

CHK-SSH-21 — PermitUserEnvironment debe estar en 'no'

Referencia CIS: 5.1.21

Severidad: MEDIA

Explicación breve:

Evita carga de configuraciones maliciosas.

Evidencia:

```
Línea 4: PermitUserEnvironment yes
```

Recomendación:

```
PermitUserEnvironment no
```

CHK-SSH-22 — UsePAM debe estar en 'yes'

Referencia CIS: 5.1.22

Severidad: MEDIA

Explicación breve:

PAM añade controles avanzados de autenticación.

Evidencia:

```
Línea 21: UsePAM no
```

Recomendación:

```
UsePAM yes
```

CHK-SSH-18 — MaxStartups no definido

Referencia CIS: 5.1.18

Severidad: MEDIA

Explicación breve:

Evita DoS mediante conexiones simultáneas.

Evidencia:

```
Parámetro no encontrado en sshd_config
```

Recomendación:

```
MaxStartups 10:30:60
```

Remediaciones Detalladas

Esta sección proporciona instrucciones extensas y completas para corregir cada hallazgo, incluyendo impacto técnico, pasos detallados y validaciones posteriores.

CHK-SSH-1 — Permisos inseguros en sshd_config

Impacto técnico:

Permisos incorrectos permiten modificar configuración crítica de SSH.

Pasos de remediación:

1. Revisar permisos actuales:
`sudo ls -l /etc/ssh/`
2. Aplicar permisos seguros típicos:
`sudo chmod 600 /etc/ssh/ssh_host_*`
`sudo chown root:root /etc/ssh/ssh_host_*`
3. Seguir las recomendaciones exactas:
`chmod 600 /etc/ssh/sshd_config`
4. Recargar SSH (si aplica):
`sudo systemctl reload sshd`

Validación posterior:

Validación:
`sudo stat -c "%a %U %G" /etc/ssh/ssh_host_*`
--> Los archivos deben ser propiedad de root:root y con permisos 600.

CHK-SSH-4 — Falta AllowUsers o AllowGroups

Impacto técnico:

Limitar usuarios reduce superficie de ataque.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  no se encontró ninguna línea allowusers ni allowgroups

3. Reemplazar por:
  Añadir AllowUsers <usuario>

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep allowusers --> Debe aparecer: Añadir AllowUsers
```

CHK-SSH-5 — SSH Banner no configurado

Impacto técnico:

Un banner legal advierte sobre uso no autorizado.

Pasos de remediación:

```
1. Editar o crear el banner:
  sudo nano /etc/issue.net

2. Añadir texto legal corporativo.

3. Configurar SSH para usarlo:
  sudo nano /etc/ssh/sshd_config
  Banner /etc/issue.net

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep banner --> Debe aparecer: banner /etc/issue.net
```

CHK-SSH-6 — Ciphers inseguros detectados

Impacto técnico:

Los cifrados CBC son débiles frente a ataques conocidos.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  se encontró el cipher inseguro: aes128-cbc

3. Reemplazar por:
  Ciphers aes256-ctr,aes192-ctr,aes128-ctr

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep ciphers --> Debe aparecer: Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

CHK-SSH-7 — ClientAliveInterval demasiado alto

Impacto técnico:

Valores altos retrasan tiempo de detección de sesiones muertas.

Pasos de remediación:

```
1. Editar SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 12: clientaliveinterval 600

3. Cambiar por:
  ClientAliveInterval 300

4. Recargar:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep clientalive --> Debe verse: ClientAliveInterval 300
```


CHK-SSH-7 — ClientAliveCountMax demasiado alto

Impacto técnico:

Evita mantener sesiones inactivas por demasiado tiempo.

Pasos de remediación:

```
1. Editar SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 13: clientalivecountmax 10

3. Cambiar por:
  ClientAliveCountMax 3

4. Recargar:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep clientalive --> Debe verse: ClientAliveCountMax 3
```

CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

Impacto técnico:

Evita tunelización no autorizada.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 14: allowtcpforwarding yes

3. Reemplazar por:
  AllowTcpForwarding no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep allowtcpforwarding --> Debe aparecer: AllowTcpForwarding no
```

CHK-SSH-9 — GSSAPIAuthentication debe estar en 'no'

Impacto técnico:

Reduce superficie de ataque en autenticación.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 15: gssapiauthentication yes

3. Reemplazar por:
  GSSAPIAuthentication no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep gssapiauthentication --> Debe aparecer: GSSAPIAuthentication no
```

CHK-SSH-10 — HostbasedAuthentication debe estar en 'no'

Impacto técnico:

Evita autenticación basada en confianza entre hosts.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 2: hostbasedauthentication yes

3. Reemplazar por:
  HostbasedAuthentication no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep hostbasedauthentication --> Debe aparecer: HostbasedAuthentication no
```

CHK-SSH-11 — IgnoreRhosts debe estar en 'yes'

Impacto técnico:

Los archivos rhosts son altamente inseguros.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 3: ignorerhosts no

3. Reemplazar por:
  IgnoreRhosts yes

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep ignorerhosts --> Debe aparecer: IgnoreRhosts yes
```

CHK-SSH-13 — LoginGraceTime debe ser 60 o menos

Impacto técnico:

Reduce ventana para ataques de fuerza bruta.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 8: logingracetime 120

3. Reemplazar por:
  LoginGraceTime 60

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep logingracetime --> Debe aparecer: LoginGraceTime 60
```

CHK-SSH-14 — LogLevel incorrecto

Impacto técnico:

Nivel adecuado permite registrar actividad sospechosa.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 20: loglevel debug

3. Reemplazar por:
  LogLevel INFO

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep loglevel --> Debe aparecer: LogLevel INFO
```

CHK-SSH-16 — MaxAuthTries demasiado alto

Impacto técnico:

Evita ataques de fuerza bruta.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 7: maxauthtries 10

3. Reemplazar por:
  MaxAuthTries 4

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep maxauthtries --> Debe aparecer: MaxAuthTries 4
```

CHK-SSH-17 — MaxSessions demasiado alto

Impacto técnico:

Evita abuso de sesiones múltiples.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 19: maxsessions 50

3. Reemplazar por:
  MaxSessions 10

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep maxsessions --> Debe aparecer: MaxSessions 10
```

CHK-SSH-19 — PermitEmptyPasswords debe ser 'no'

Impacto técnico:

Evita sesiones sin contraseña.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 6: permitemptypasswords yes

3. Reemplazar por:
  PermitEmptyPasswords no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep permitemptypasswords --> Debe aparecer: PermitEmptyPasswords no
```

CHK-SSH-20 — PermitRootLogin debe estar en 'no'

Impacto técnico:

Evita accesos directos al usuario root.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 5: permitrootlogin yes

3. Reemplazar por:
  PermitRootLogin no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep permitrootlogin --> Debe aparecer: PermitRootLogin no
```

CHK-SSH-21 — PermitUserEnvironment debe estar en 'no'

Impacto técnico:

Evita carga de configuraciones maliciosas.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 4: permituserenvironment yes

3. Reemplazar por:
  PermitUserEnvironment no

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep permituserenvironment --> Debe aparecer: PermitUserEnvironment no
```

CHK-SSH-22 — UsePAM debe estar en 'yes'

Impacto técnico:

PAM añade controles avanzados de autenticación.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  línea 21: usepam no

3. Reemplazar por:
  UsePAM yes

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep usepam --> Debe aparecer: UsePAM yes
```

CHK-SSH-18 — MaxStartups no definido

Impacto técnico:

Evita DoS mediante conexiones simultáneas.

Pasos de remediación:

```
1. Editar archivo SSH:
  sudo nano /etc/ssh/sshd_config

2. Localizar:
  parámetro no encontrado en sshd_config

3. Reemplazar por:
  MaxStartups 10:30:60

4. Recargar SSH:
  sudo systemctl reload sshd
```

Validación posterior:

```
sshd -T | grep maxstartups --> Debe aparecer: MaxStartups 10:30:60
```

Playbooks de Seguridad

Esta sección presenta escenarios de explotación y defensa basados en los hallazgos detectados. Los playbooks están contruidos usando tácticas MITRE ATT&CK, Kill Chain y técnicas de Red Team.

Playbook SSH

```
Táctica: Initial Access
Técnica: T1110 - Password Brute Force

1. Descubrimiento de servicio:
  nmap -p 22 Localhost

2. Ataque de fuerza bruta:
  hydra -l root -P rockyou.txt ssh://Localhost

3. Pivoting si AllowTcpForwarding = yes:
  ssh -L 3306:localhost:3306 user@Localhost

4. Persistencia:
  echo "clave_maliciosa" >> ~/.ssh/authorized_keys
```

Playbook Firewall (UFW)

```
Escenario: Puerto crítico expuesto

1. Detección:
  nmap -sV -p 3306,6379,27017 Localhost

2. Explotación:
  Conectar al servicio expuesto con credenciales débiles.

3. Elevación:
  Explotar service misconfigurations.

4. Defensa:
  ufw deny 3306
```

Conclusión Técnica

El análisis realizado ha permitido identificar configuraciones inseguras, servicios

expuestos y parámetros críticos que requieren remediación prioritaria. La combinación de hallazgos indica un riesgo operativo significativo si no se implementan las acciones de mitigación proporcionadas.

Se recomienda priorizar las remediaciones de severidad **Crítica** y **Alta**, ya que representan rutas directas de compromiso del sistema. Una vez implementadas las correcciones, puede ejecutarse un nuevo análisis para verificar la efectividad del endurecimiento.

Este informe proporciona una base sólida para el hardening continuo del entorno, permitiendo avanzar hacia un sistema alineado con CIS Benchmark y mejores prácticas de la industria.